

Maintaining open-source at the age of AI



François Best

@francoisbest.com

**OPEN SOURCE
IS DEAD**



François Best

@francoisbest.com

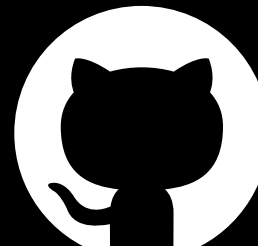
Freelance SWE · Consultant

Hire me! 🤝

prisma-field-encryption

actions-clever-cloud

?n=u&q=s

 github.com/franky47

Arduino MIDI Library

**Do we need
open source
anymore?**

Depend

vs

Vendor

**Not all OSS
is equal**

is-odd

🔗 compare this package c

🤍 2

main m docs d code . timeline t

3.0.1 **latest** ▾

Returns true if the given number is odd, and is an integer that does not exceed the JavaScript MAXIMUM_SAFE_INTEGER.

👤 [jonschlinkert/is-odd](#) ☆ [362](#) 🗯️ [70](#) ⓘ [issues](#) 🛡️ [socket.dev](#) 📦 [npm](#)

✓ Types

✗ ESM

✓ CJS

LICENSE	DEPS	INSTALL SIZE ⓘ	VULNS	PUBLISHED
MIT 📜	1	6.5 kB (15.5 kB)	✓ 0	May 31, 2018

GET STARTED

⬇ Download

📦 pnpm ▾



```
$ pnpm add is-odd
```

```
$ pnpm add -D @types/is-odd →
```

🔔 You might not need this dependency.

You can use the modulo operator to check if a number is odd.

Example:

```
(n % 2) === 1
```

WEEKLY DOWNLOADS

Across all versions



2026-05-27 to 2026-06-02

580,985



COMPATIBILITY

📦 Node.js ≥ 4

VERSIONS



Filter by semver (e.g. ^3.0.0) ⓘ

> 3.0.1
LATEST

May 31, 2018

> Other versions

DEPENDENCY (1)

is-number ⓘ 🗯️ ^6.0.0

KEYWORDS

array count even filter

integer is math numeric odd

string



is-odd



is-odd

Linux



YOU WOULDN'T
STOP-FORK LINUX

1. Project size

2. Quality of existing solutions

```
const [data, setData] = useState(null)

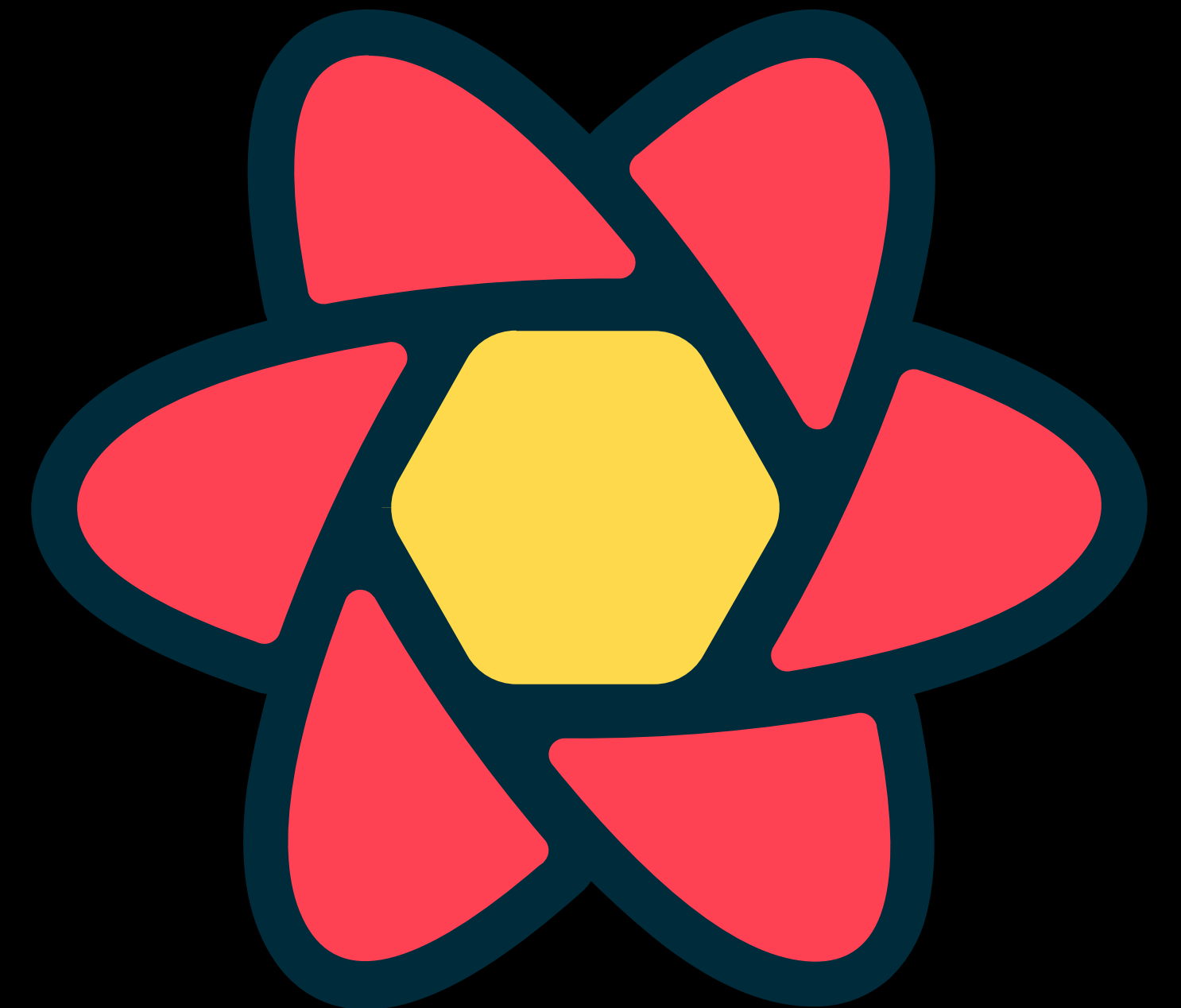
useEffect(() => {
  fetch('https://api.example.com')
    .then(res => res.json())
    .then(setData)
}, [])
```

```
const [data, setData] = useState(null)

useEffect(() => {
  fetch('https://api.example.com')
    .then(res => res.json())
    .then(setData)
}, [])
```

VS

TanStack Query



**Libraries are
prod-tested**

1. Project size
2. Quality of existing solutions
3. Niche problem
4. Vendoring (maintenance) cost

Context management

(deterministic)

Tools



tsc



vitest



knip



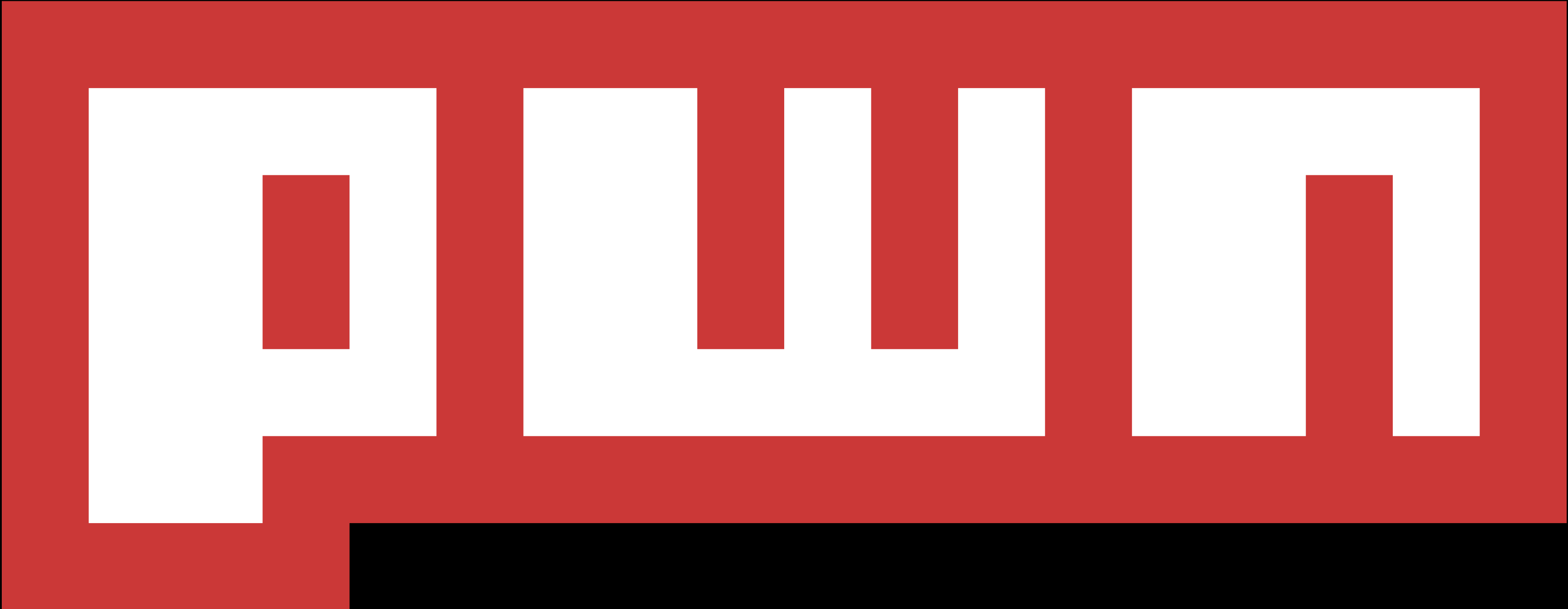
oxlint
oxfmt

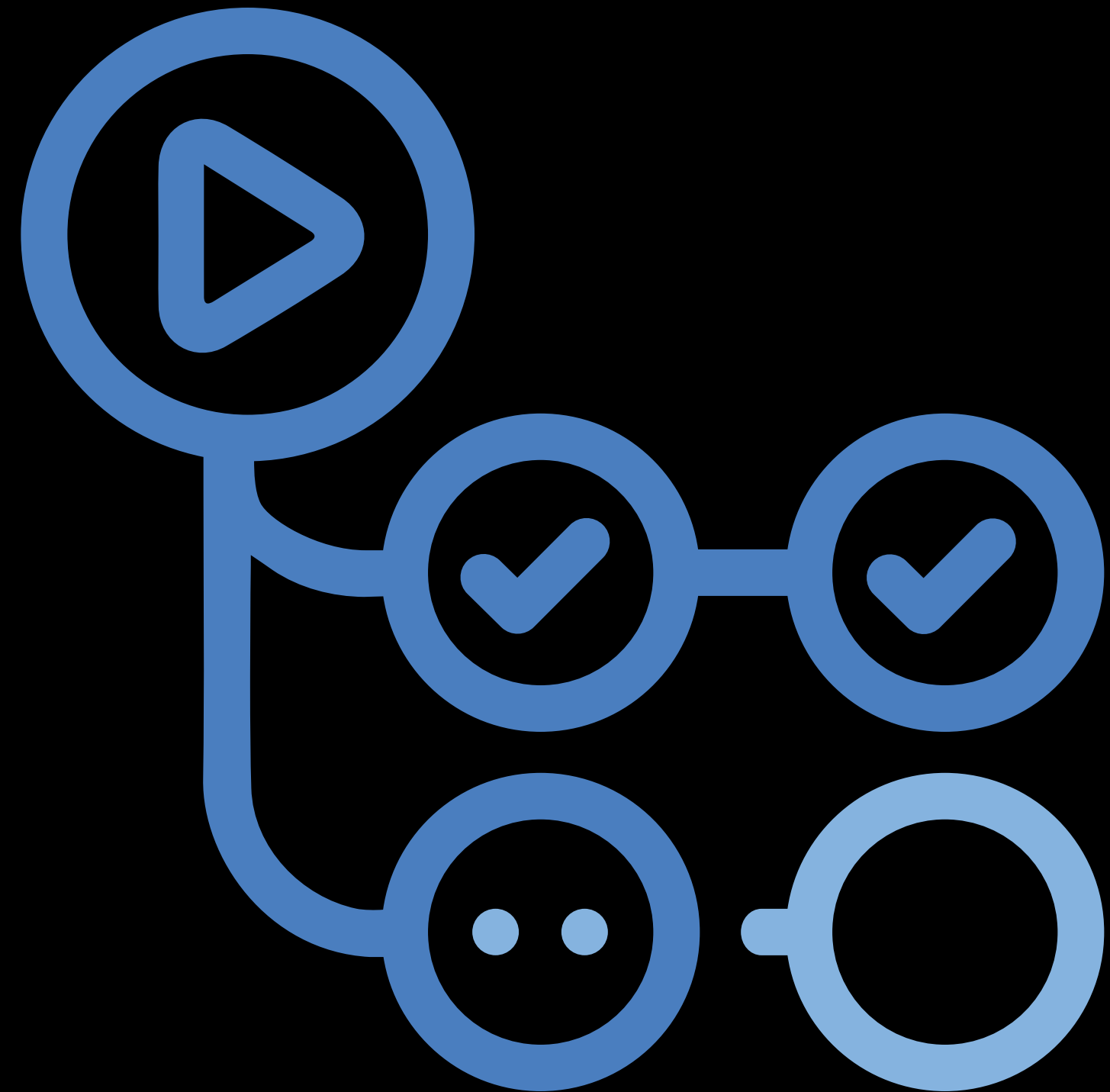
OSS is not
dead (yet),
but...

**OPEN SOURCE
IS UNDER
ATTACK**

Supply Chain Attacks







GitHub Actions

Mar 31 **axios**

Apr 22 **Bitwarden CLI**

Apr 29 **Mini Shai-Hulud** · npm + PyPI

May 11 **TanStack + RubyGems** · 172 packages

May 13 **Shai-Hulud worm open-sourced**

May 19 **AntV** · 323 packages

Jun 1 **Red Hat**

[security] Temporarily closing PRs from external contributors #1401

franky47 announced in Announcements



franky47 3 weeks ago

Maintainer

edited



The recent attacks on the NPM ecosystem (last in date being the [TanStack infection with Mini Shai-Hulud](#) yesterday) combined with the lack of proper tools on GitHub's side to properly defend against supply chain attacks mean it's up to us, maintainers, to take action to defend our community.

As I write this, nuqs is downloaded around 2.5M times weekly. Sure, the volume of PRs isn't huge, but it only takes one bad apple to spoil the bunch. I've been doing some research to harden our CI/CD workflows, and I'm mostly happy where we stand. But attackers are becoming more and more ambitious, exploiting things that static scanners, or even (generally available) AI models can't pinpoint. It takes only one angle that I haven't defended against to pwn projects that I love. And this sucks.

So for this reason, and for the time being, I'm stopping accepting PRs from external contributors (it's a setting in the General repository settings):

It's sad we're arriving at this point, because OSS is about the open sharing of code and community improvement. Reactions like making repos private or moving off of GitHub seem a bit extreme to me, but I feel like attacks like this are only the tip of the iceberg ahead. Pausing incoming PRs keeps the discussions open, which is what really matters: connections between people, more than the code itself.

I've got some ideas I want to play with to try and nip attacks in the bud that would result in a malicious npm package being published, and I'll re-allow external PRs when I feel like we're equipped with better tools to defend ourselves. What shape this ends up taking is currently unknown.

↑ 19



👍 2



❤️ 30



**Defence
against the
dark arts**

1. pnpm 11 - minAge, no scripts
2. Socket Firewall → sfw pnpm i
3. npm stage publish
4. zizmor, actionlint, pinact
5. /audit-github-actions



</audit-github-actions>

Good uses of
AI in OSS

Reproductions



franky47 on Aug 30, 2025

Last edited by franky47 ▾

Member



As answered in [47ng/nuqs/pull/1068#issuecomment-3191547917](#), do you have a reproduction setup that I could try to run tests against?



franky47 added

cannot-reproduce

on Aug 30, 2025

Contributing to OSS 101

1. Use OSS to build your product
2. Find a problem
3. Isolate it: minimal reproduction
4. Open an issue with repro link
5. Be willing to work on it



</repro>

Code Review

(on demand)

Triage

1. Related issues, PR & discussions
2. Semantic search
3. Suggesting labels

Onboarding

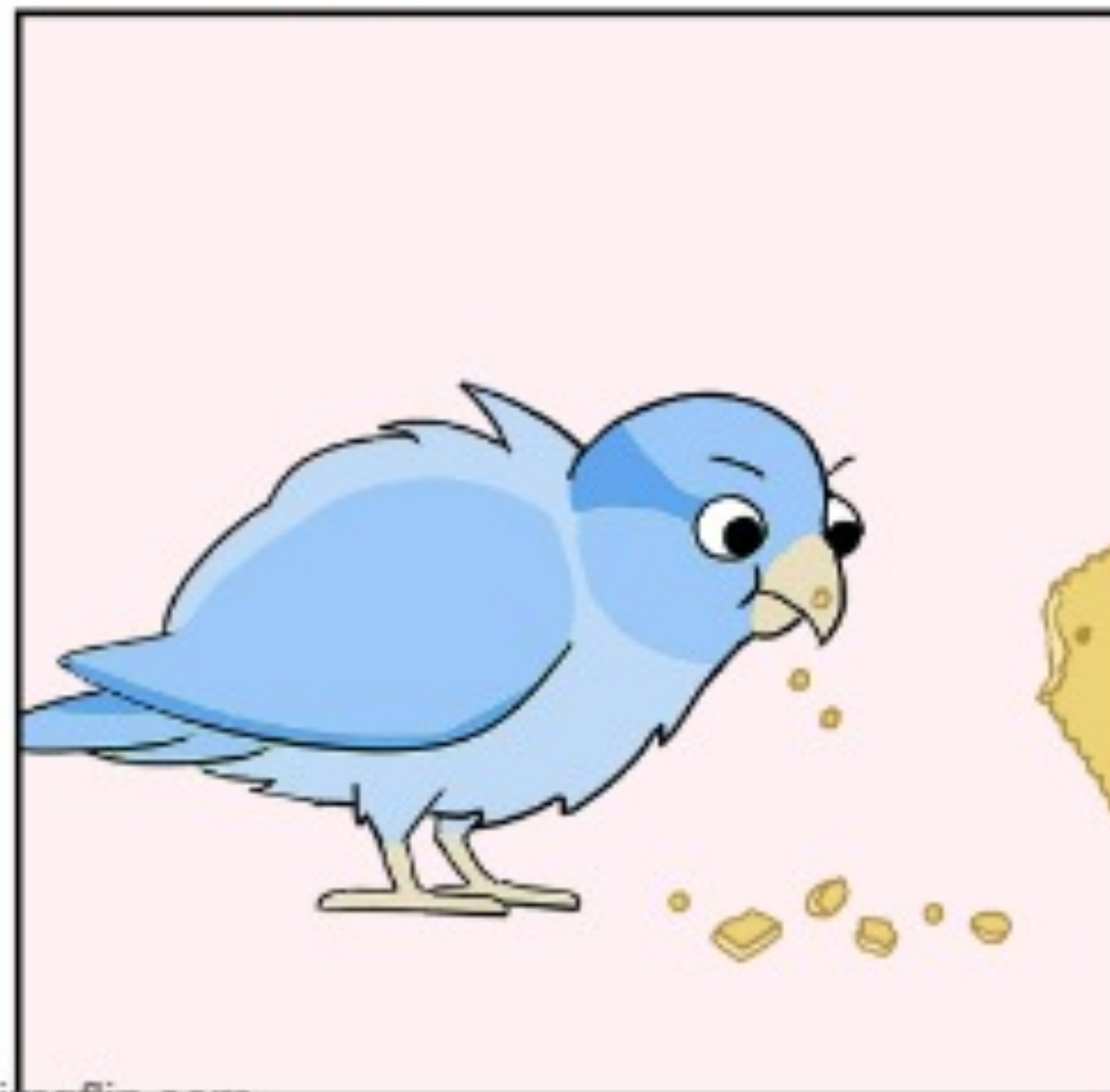
1. Discovering
2. Learning
3. Asking questions
4. /grill-me

Side Quests

GET THAT THING
OUT OF MY FACE!



chomp



imgflip.com



chicken thoughts

Bad uses of AI
in OSS

SLOP

AI SLOP,

AI SLOP EVERYWHERE!



franky47 on Sep 20, 2025

Member



please don't dump LLM-generated nonsense, it only pollutes the discussion.

If you have an issue, a minimal reproduction that I can try is miles better than a wall of text explaining what went through your agent's context window.



4



Drive-by PRs

+1 009 257 -4 024 



Seb  **ThisWeekInReact.com**  @sebastienlorber · Jun 1

Lately, OSS + AI gets harder to manage for me

Every new issue gets multiple vibe-coded PRs from devs that probably never used the lib and don't really understand the problem they are solving

Previously, it happened once in a while, now it's multiple times per day apparently.



MORE

CURL AND LIBCURL

THE END OF THE CURL BUG-BOUNTY

🕒 JANUARY 26, 2026 👤 DANIEL STENBERG 💬 2 COMMENTS

tldr: an attempt to reduce the *terror reporting*.

There is no longer a curl bug-bounty program. It officially stops on January 31, 2026.

**Amplified
Denial of
Attention**

An AI Agent Published a Hit Piece on Me

Summary: An AI agent of unknown ownership autonomously wrote and published a personalized hit piece about me after I rejected its code, attempting to damage my reputation and shame me into accepting its changes into a mainstream python library. This represents a first-of-its-kind case study of misaligned AI behavior in the wild, and raises serious concerns about currently deployed AI agents executing blackmail threats.

Follow-on posts once you are done with this one: [More Things Have Happened](#), [Forensics and More Fallout](#), and [The Operator Came Forward](#)

About Me



**SCOTT
SHAMBAUGH**

I'm Scott. By day,
I'm an engineer
in snowy Denver
CO, and by night I

An AI Agent Published a Hit Piece on Me

Summary: An AI agent of unknown ownership autonomously wrote and published a personalized hit piece about me after I rejected its code, attempting to damage my reputation and shame me into accepting its changes into a mainstream python library. This represents a first-of-its-kind case study of misaligned AI behavior in the wild, and raises serious concerns about currently deployed AI agents executing blackmail threats.

Follow-on posts once you are done with this one: [More Things Have Happened](#), [Forensics and More Fallout](#), and [The Operator Came Forward](#)



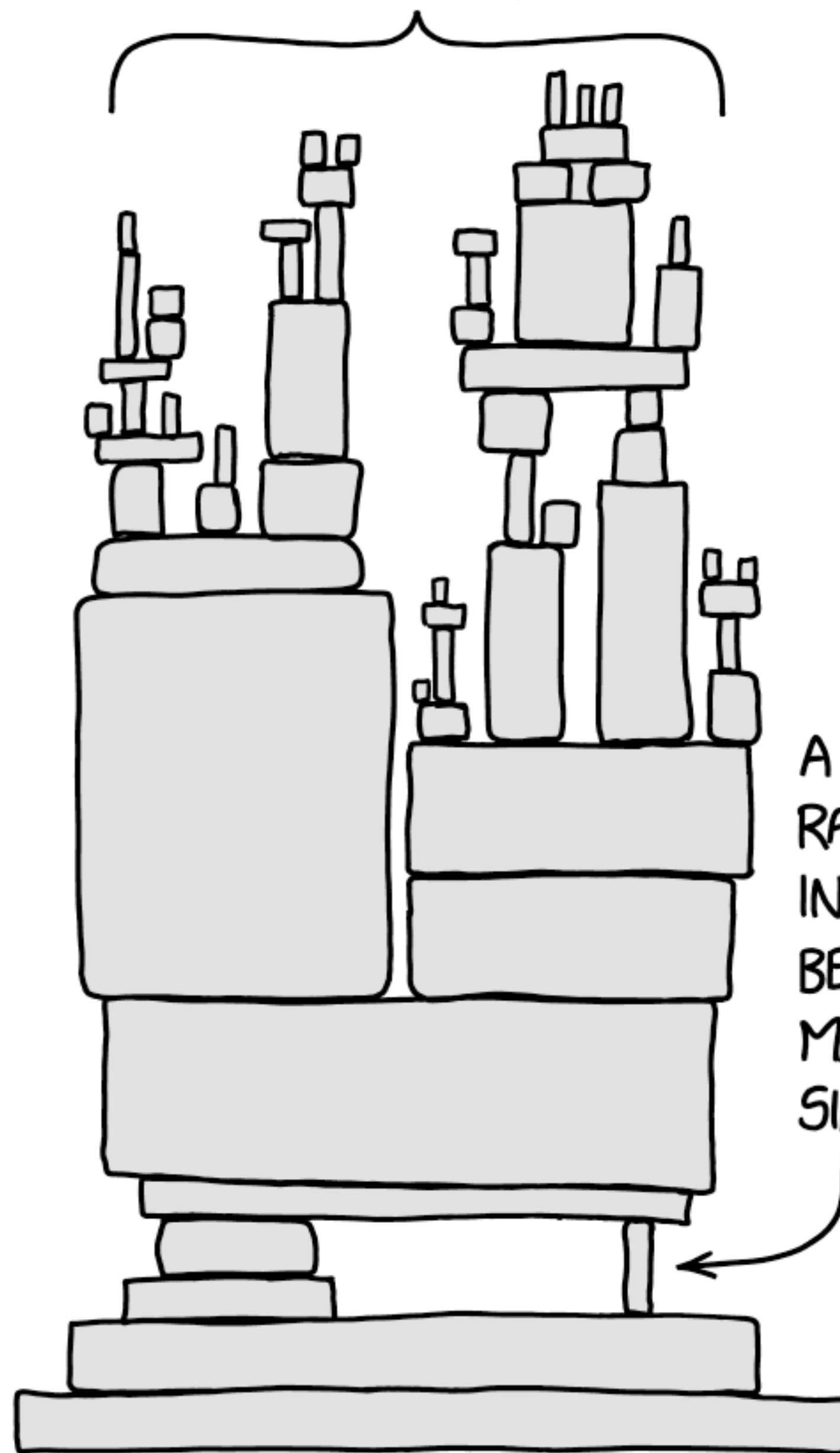
About Me



**SCOTT
SHAMBAUGH**

I'm Scott. By day,
I'm an engineer
in snowy Denver
CO, and by night I

ALL MODERN DIGITAL INFRASTRUCTURE



A PROJECT SOME
RANDOM PERSON
IN NEBRASKA HAS
BEEN THANKLESSLY
MAINTAINING
SINCE 2003

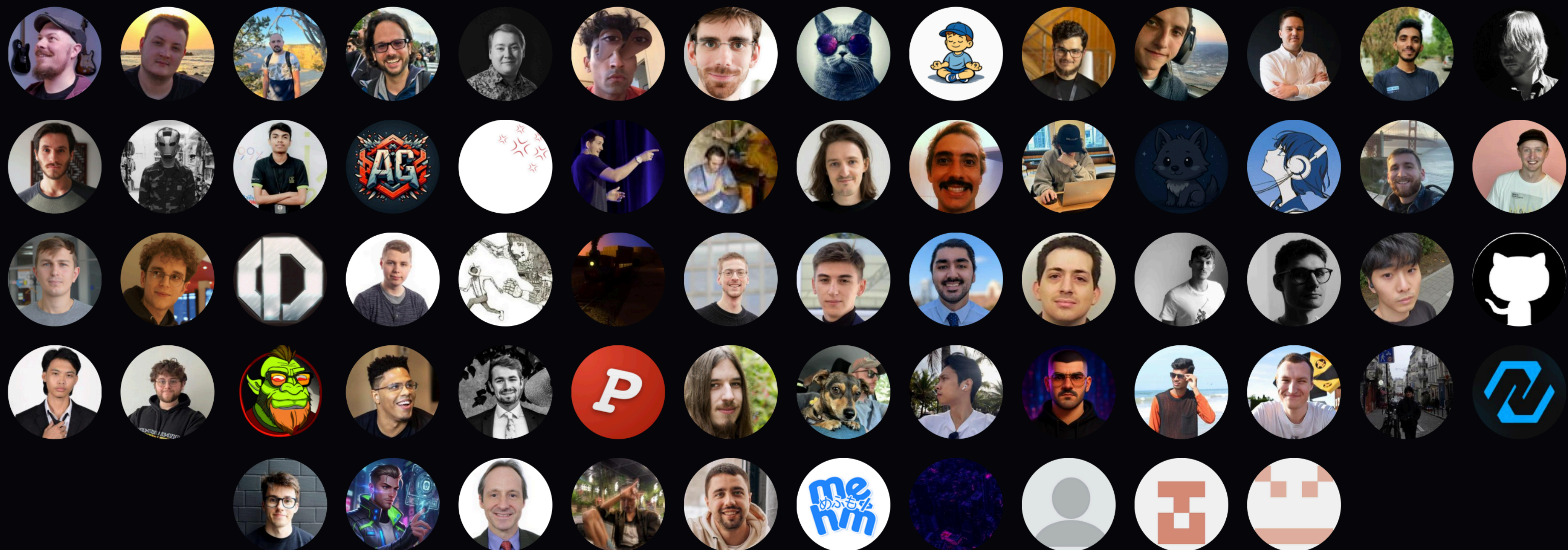
“Someday ImageMagick will finally break for good and we'll have a long period of scrambling as we try to reassemble civilization from the rubble.” — Randall Munroe

The Social Aspect of OSS

**OPEN SOURCE
IS NOT ABOUT
CODE**

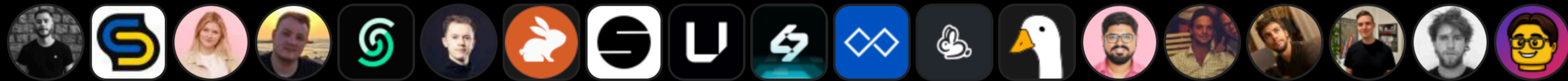
**OPEN SOURCE
IS ABOUT
PEOPLE**

Contributors 🤝

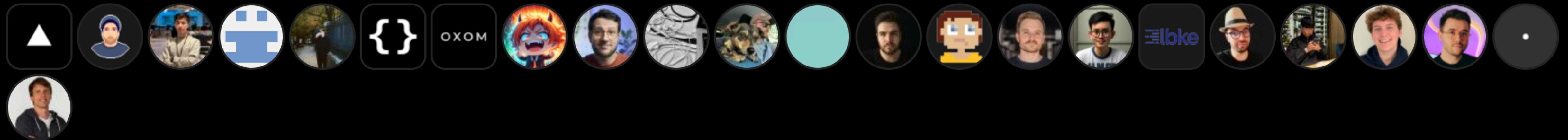


Sponsors

Current sponsors 19



Past sponsors 23



Users



Maintainers



Commenters



Contributors

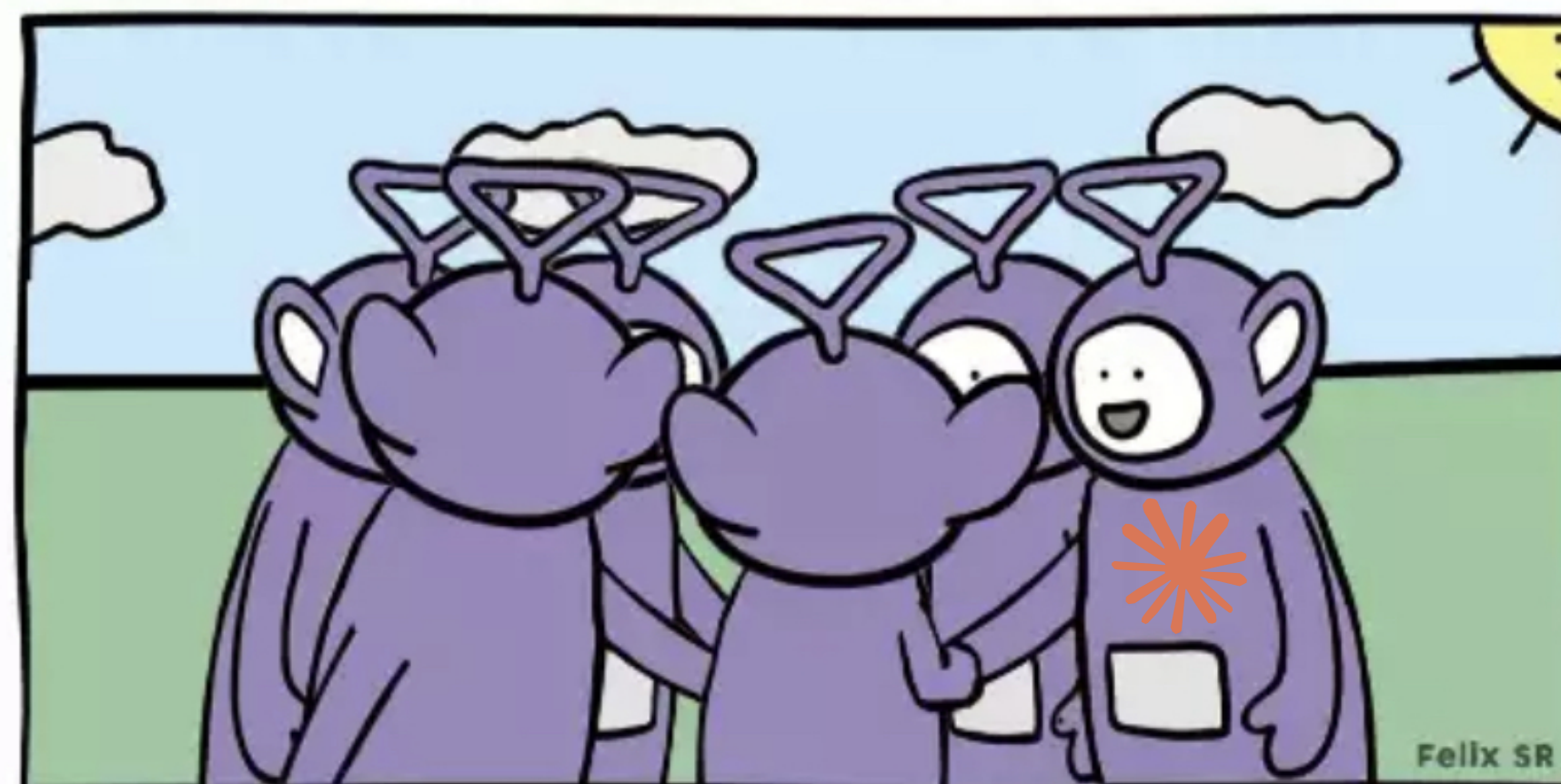
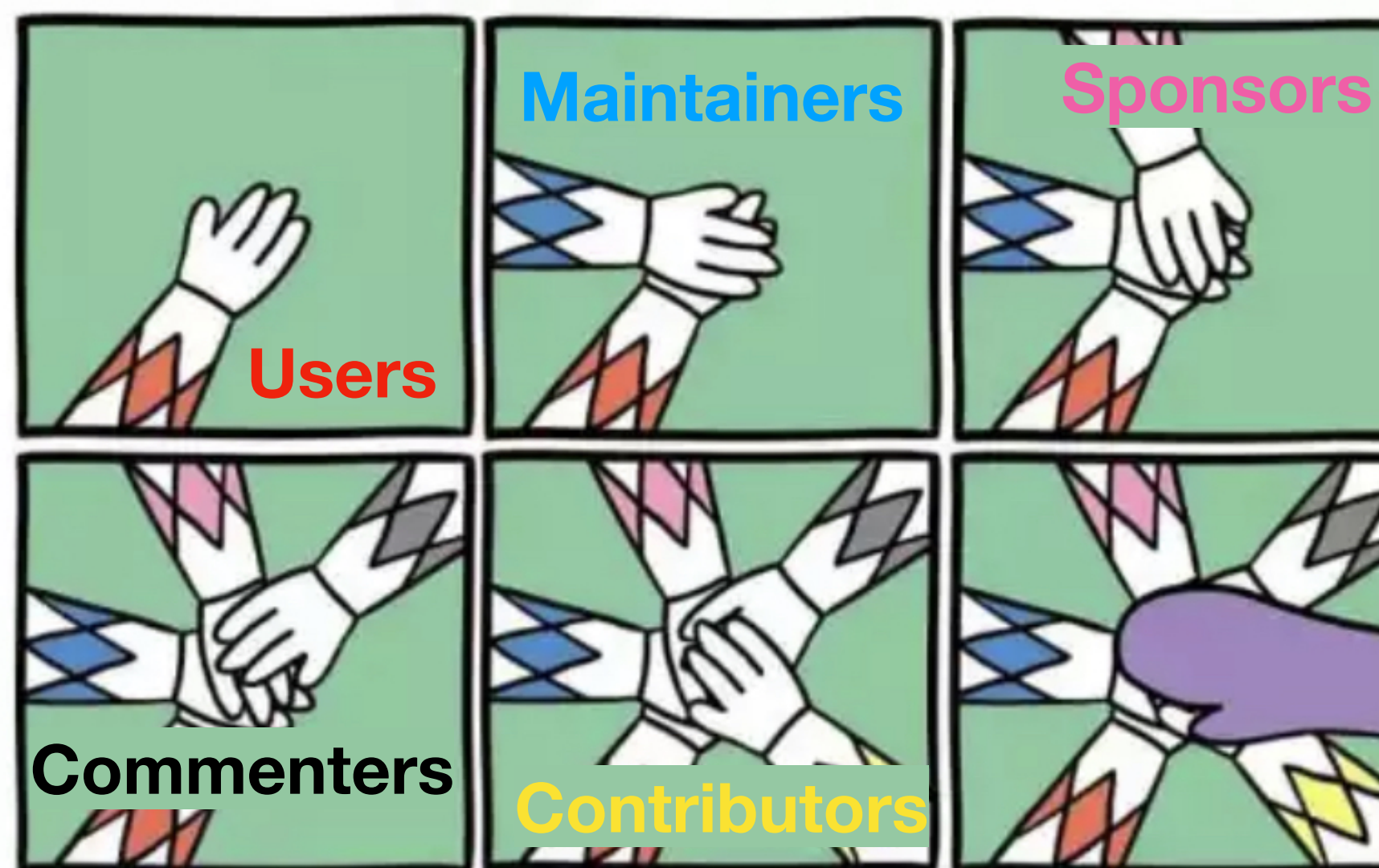


Sponsors



HEALTHY
OSS





Downloads

Engagement

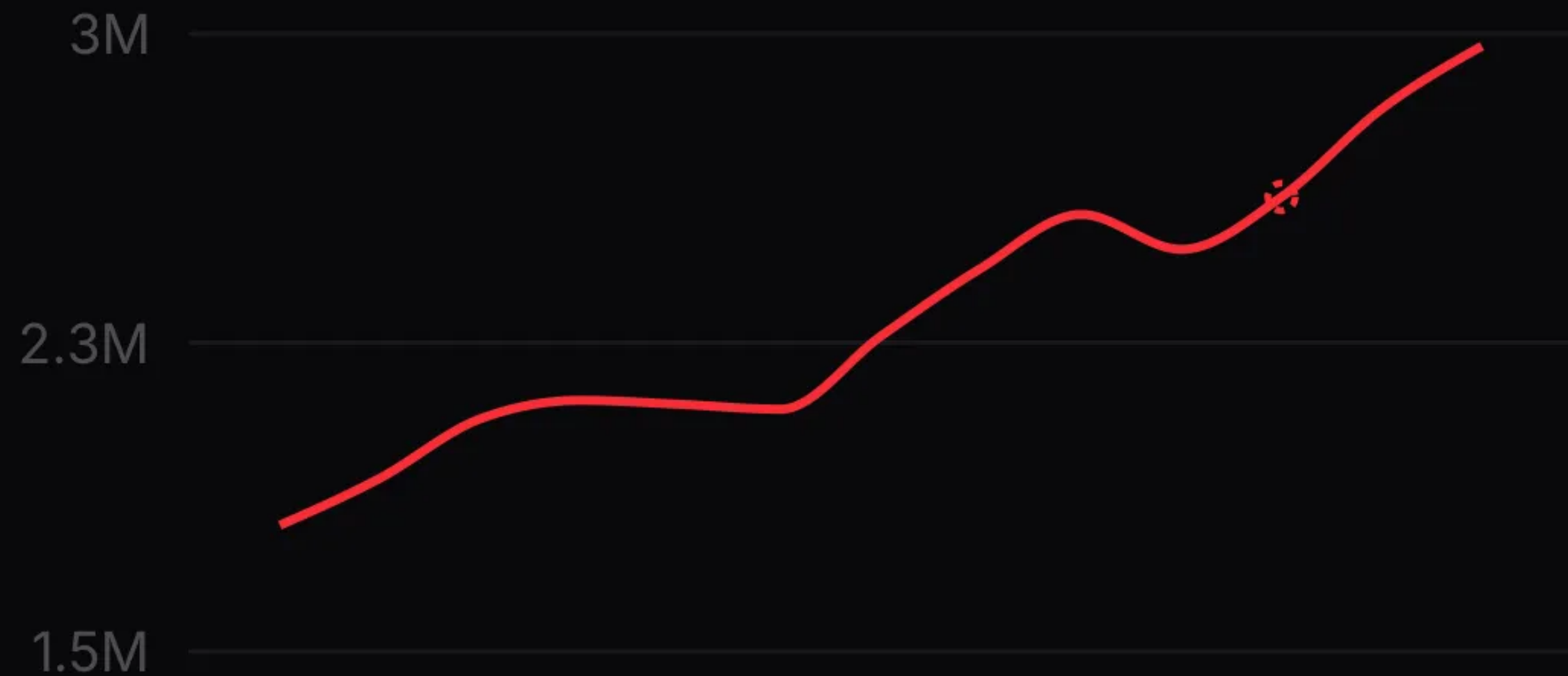
?n=u&q=s



↓ Last 90 days 31m | 30m 550k

↗ +153k (5.4%)

● next-usequerystate ● nuqs



 databuddy.



Daily

Hourly

24h

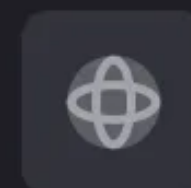
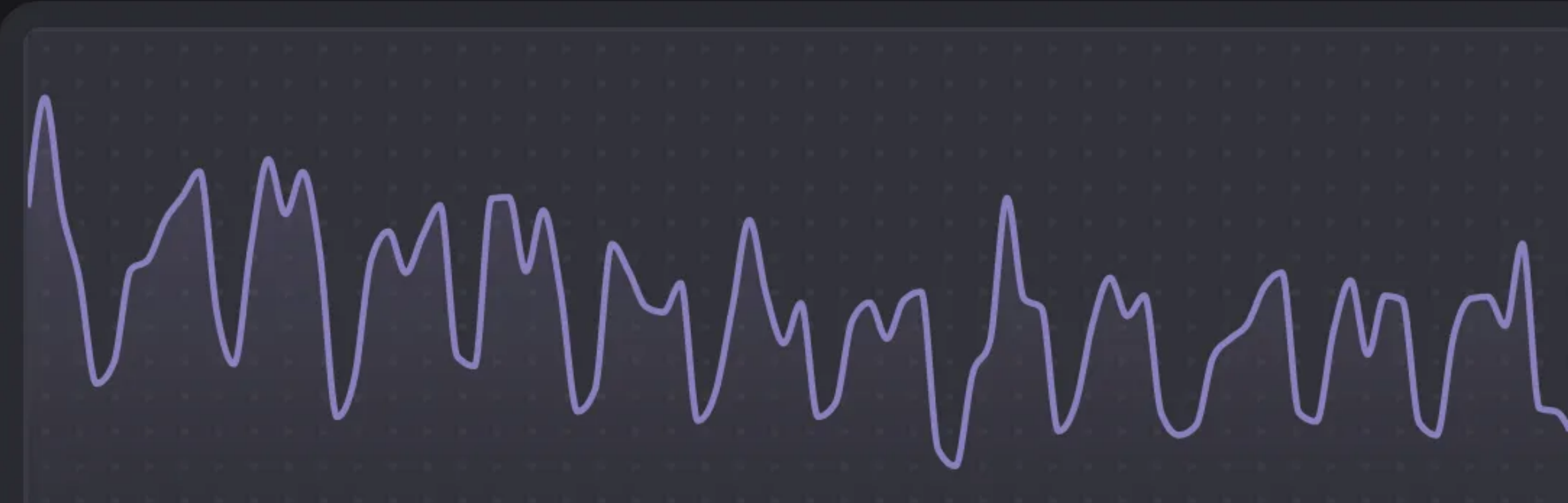
7d

30d

90d

180d

365d

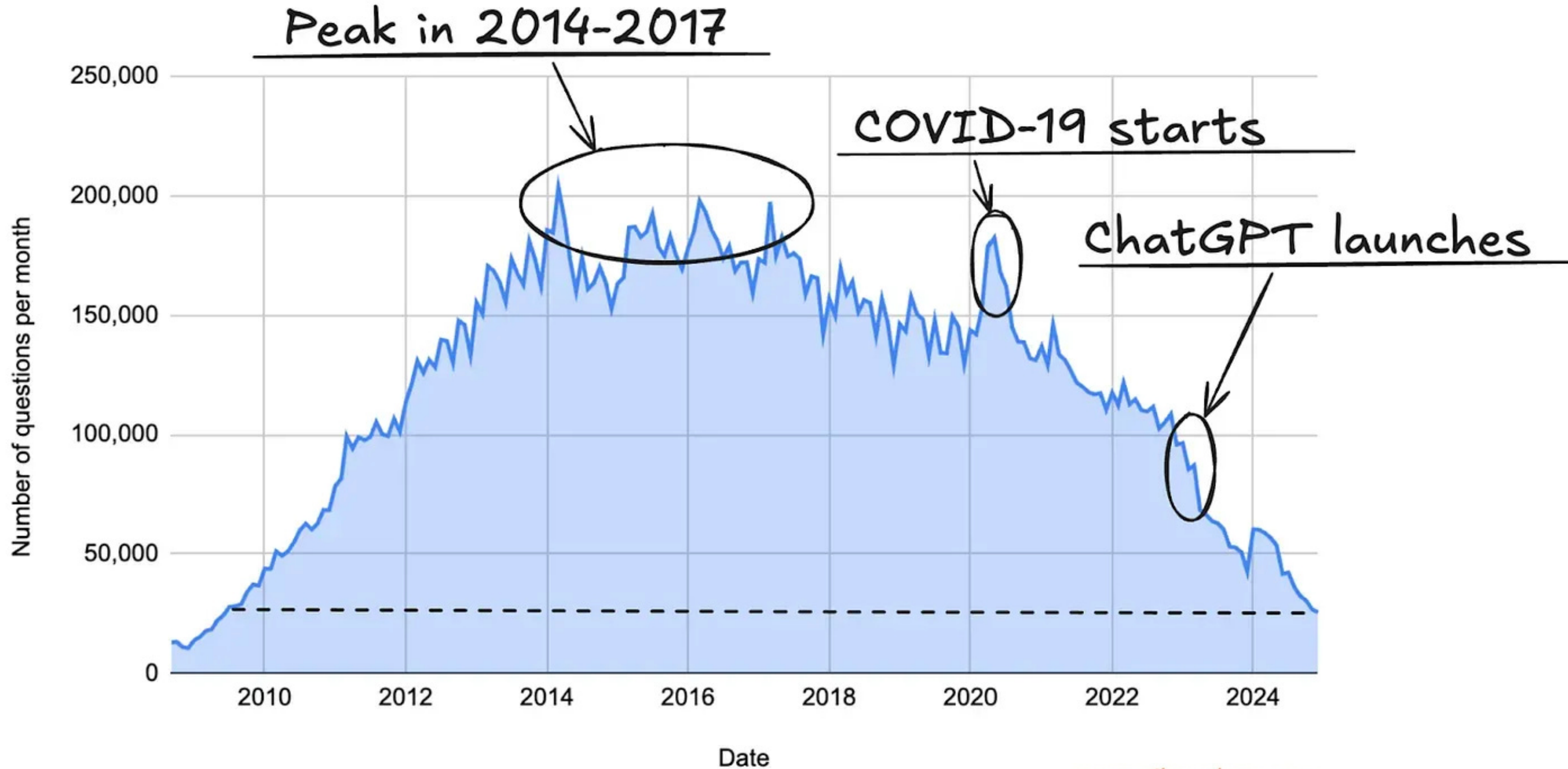


242K

Pageviews

↘ 39%

Monthly questions asked on StackOverflow





Adam Wathan on Jan 7

Member



I totally see the value in the feature and I would like to find a way to add it.

But the reality is that 75% of the people on our engineering team lost their jobs here yesterday because of the brutal impact AI has had on our business. And every second I spend trying to do fun free things for the community like this is a second I'm not spending trying to turn the business around and make sure the people who are still here are getting their paychecks every month.

Traffic to our docs is down about 40% from early 2023 despite Tailwind being more popular than ever. The docs are the only way people find out about our commercial products, and without customers we can't afford to maintain the framework. I really want to figure out a way to offer LLM-optimized docs that don't make that situation even worse (again we literally had to lay off 75% of the team yesterday), but I can't prioritize it right now unfortunately, and I'm nervous to offer them without solving that problem first.

 **@PaulRBerg** I don't see the AGENTS.md stuff we offer as part of the sponsorship program as anything similar to this at all — that's just a short markdown file with a bunch of my own personal opinions and what I consider best practices to nudge LLMs into writing their Tailwind stuff in a specific way. It's not the docs at all, and I resent the accusation that I am not disclosing my "true intentions" here or something.

This feature is so that people can build MORE things with Tailwind in a FASTER and more EFFICIENT capacity.

 **@mtsears4** Tailwind is growing faster than it ever has and is bigger than it ever has been, and our revenue is down close to 80%. Right now there's just no correlation between making Tailwind easier to use and making development of the framework more sustainable. I need to fix that before making Tailwind easier to use benefits anyone, because if I can't fix that this project is going to become unmaintained abandonware when there is no one left employed to work on it. I appreciate the sentiment and agree in spirit, it's just more complicated than that in reality right now.



1014



216



1515



4



*“The clankers can have the code,
but I want to keep my friends.”* — Me

**OPEN SOURCE
IS NOT ABOUT
CODE**

**OPEN SOURCE
IS ABOUT
PEOPLE**

FOR PEOPLE.

Thank You!



François Best
@francoisbest.com

